INE Hunting with Splunk Lab 3

ACTIVITY STATUS: FINISHED   Report an issue   ✕

Overview   Tasks   Solutions

Not Running

For the best experience, choose the region closest to you. Then, start the lab to begin.

MARK UNFINISHED

Select the region closest to you

US-East

Keyboard layout: US English (US)

Start lab

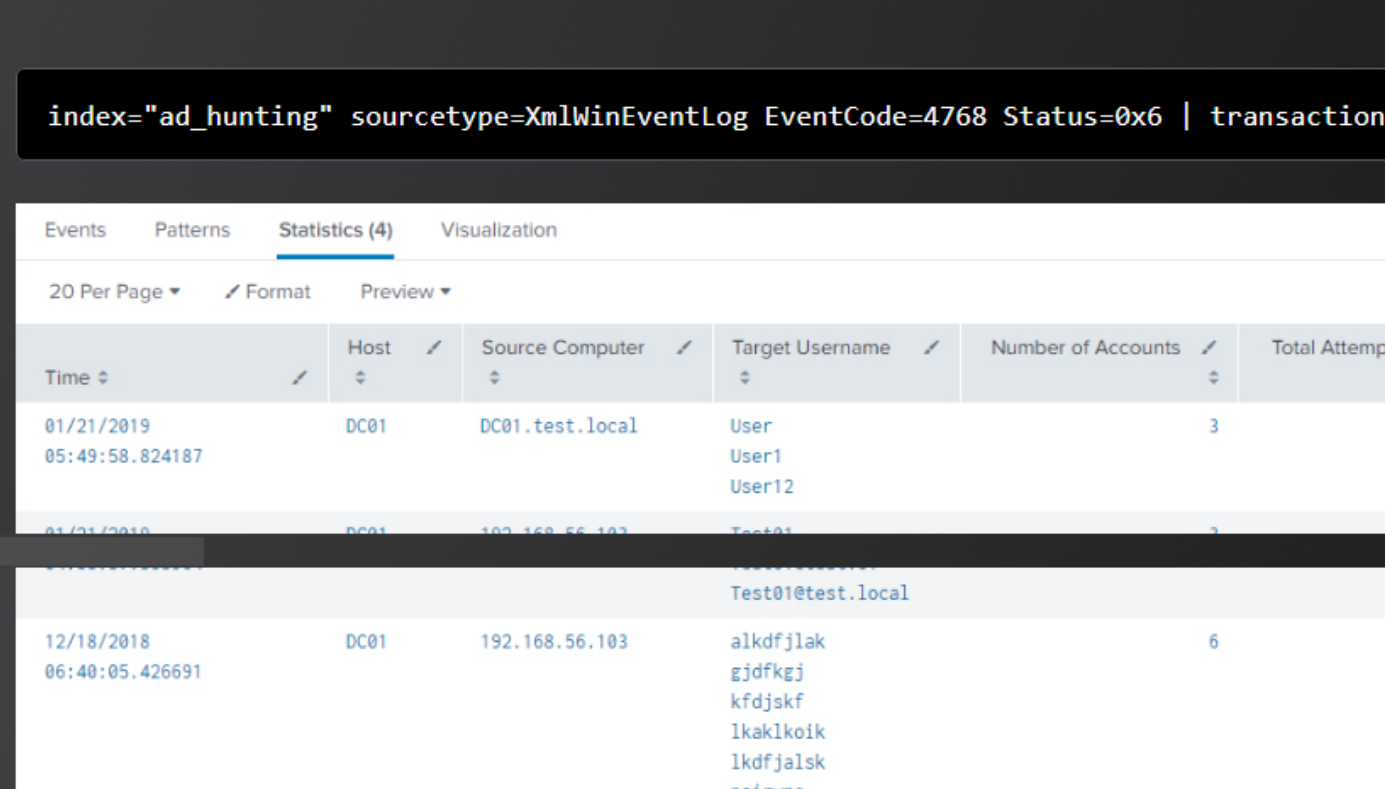
SOLUTIONS

Below, you can find solutions for each task. Remember though, that you can follow your own strategy, which may be different from the one explained in the following lab.

Task 1. Hunt for brute force attacks inside Active Directory

- **S01D01 - Logon attempts using a non-existing account (Kerberos)**

```
index="ad_hunting" sourcetype=XmlWinEventLog EventCode=4768 Status=0x6 | transaction IpAddres
```



Events   Patterns   Statistics (4)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Source Computer	Target Username	Number of Accounts	Total Attempts
01/21/2019 05:49:58.824187	DC01	DC01.test.local	User User1 User12	3	6
01/21/2019 [illegible]	DC01	192.168.56.103	Test01 [illegible] Test01@test.local	[illegible]	[illegible]
12/18/2018 06:40:05.426691	DC01	192.168.56.103	alkdfjlak gjdfkgj kfdjskf lkaklkoik lkdfjalsk poirwpe	6	12
12/18/2018 06:30:07.919192	DC01	DC01.test.local	adfjnksd asdfasd dsfasdf dskfjlasd qwerwes utyu	6	6

This search looks for events 4768 auditing Kerberos authentication ticket (TGT) requests and filters them on the *Status* field equal to code *0x6*. This value means that the submitted username does not exist [3]. The transaction command is used to group subsequent attempts coming from the same IP address with a maximal pause of 5 minutes between them. Only transactions containing more than five events are preserved. These are the conditions that define parameters of a brute force attack. If there is an IP address of *localhost* in the event, the computer name is taken as a source. The number of different usernames is calculated with the *mvcount* function of the *eval* command. The rule triggers only in the case there are attempts towards more than two different accounts.

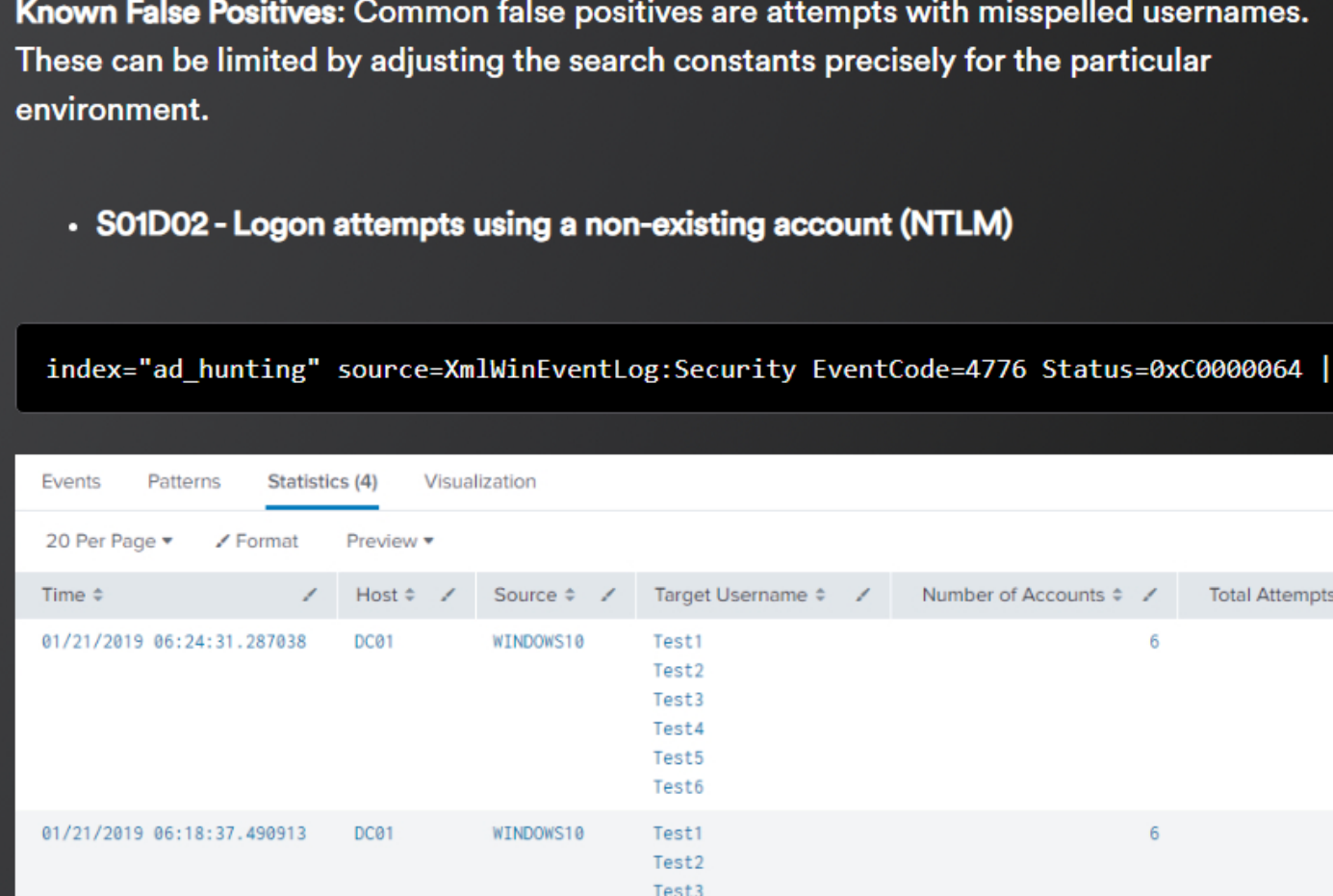
How to Implement: Logging on domain controllers needs to be set up to log TGT requests. It can be done by configuring *Audit Kerberos Authentication Service* auditing setting [3]. The

accounts, need to reflect *Account Lockout Policy* settings of the domain environment.

Known False Positives: Common false positives are attempts with misspelled usernames. These can be limited by adjusting the search constants precisely for the particular environment.

- **S01D02 - Logon attempts using a non-existing account (NTLM)**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4776 Status=0xC0000064 | transact
```



Events   Patterns   Statistics (4)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Source	Target Username	Number of Accounts	Total Attempts
01/21/2019 06:24:31.287038	DC01	WINDOWS10	Test1 Test2 Test3 Test4 Test5 Test6	6	6
01/21/2019 06:18:37.490913	DC01	WINDOWS10	Test1 Test2 Test3 Test4 Test5	6	6
01/21/2019 06:00:12.554032	DC01	WINDOWS10	Test1 Test2 Test3 Test4 Test5 Test6	6	6
01/21/2019 05:53:13.515483	DC01	DC01	Test01 Test02 Test03 Test04 Test05 Test06	6	6

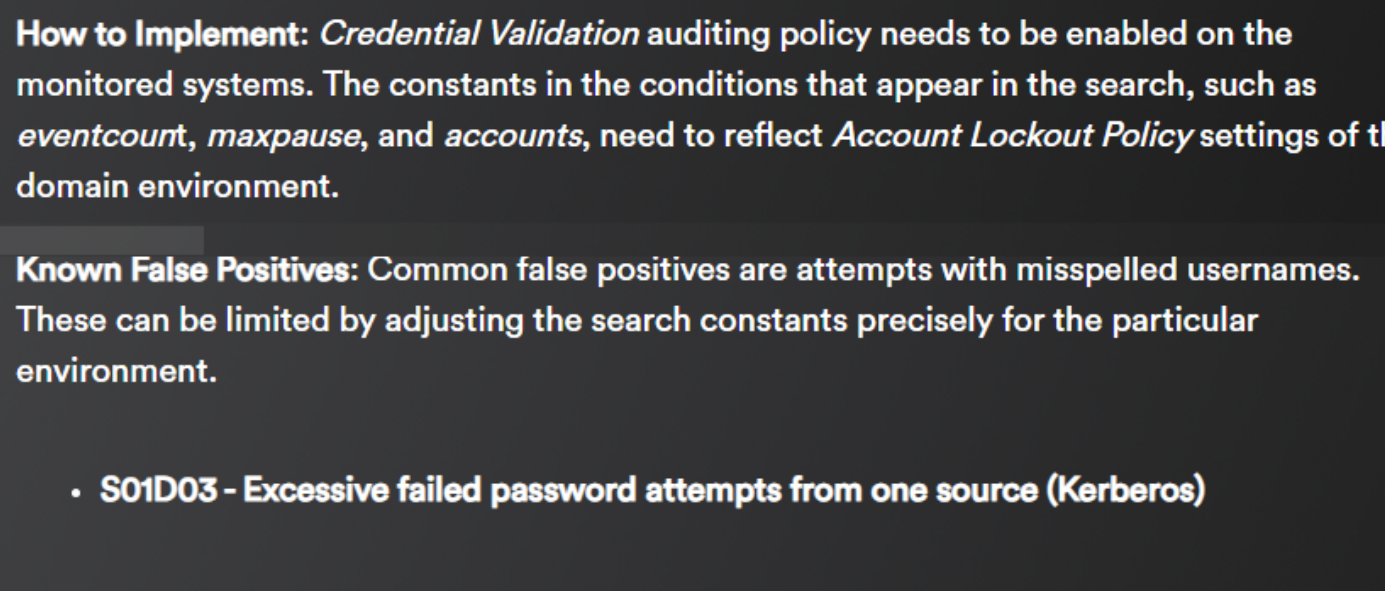
This search looks for events 4776 auditing NTLM authentication and filters them on the *Status* field equal to code *0xC0000064*. This value means that the submitted username does not exist [4]. The *transaction* command is used to group subsequent attempts coming from the same source workstation with a maximal pause of 5 minutes between them. Only transactions containing more than five events are preserved. These are the conditions that define parameters of a brute force attack. The number of different usernames is calculated with *mvcount* function of the *eval* command. The rule triggers only in the case there are attempts towards more than two different accounts.

How to Implement: *Credential Validation* auditing policy needs to be enabled on the monitored systems. The constants in the conditions that appear in the search, such as *eventcount*, *maxpause*, and *accounts*, need to reflect *Account Lockout Policy* settings of the domain environment.

Known False Positives: Common false positives are attempts with misspelled usernames. These can be limited by adjusting the search constants precisely for the particular environment.

- **S01D03 - Excessive failed password attempts from one source (Kerberos)**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4771 Status=0x18 | transaction Ip
```



Events   Patterns   Statistics (9)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Source Computer	Target Username	Number of Accounts	Total Attempts
03/11/2019 03:30:36.260659	DC01	192.168.56.103	WINDOWS10$	1	20
02/17/2019 13:21:55.937982	DC01	192.168.56.106	Administrator	1	40
02/17/2019 13:08:36.237707	DC01	192.168.56.106	Administrator	1	12
02/17/2019 08:20:09.865008	DC01	192.168.56.106	Administrator Database01	2	10

This search detects password brute force attempts coming from one source. Those may be

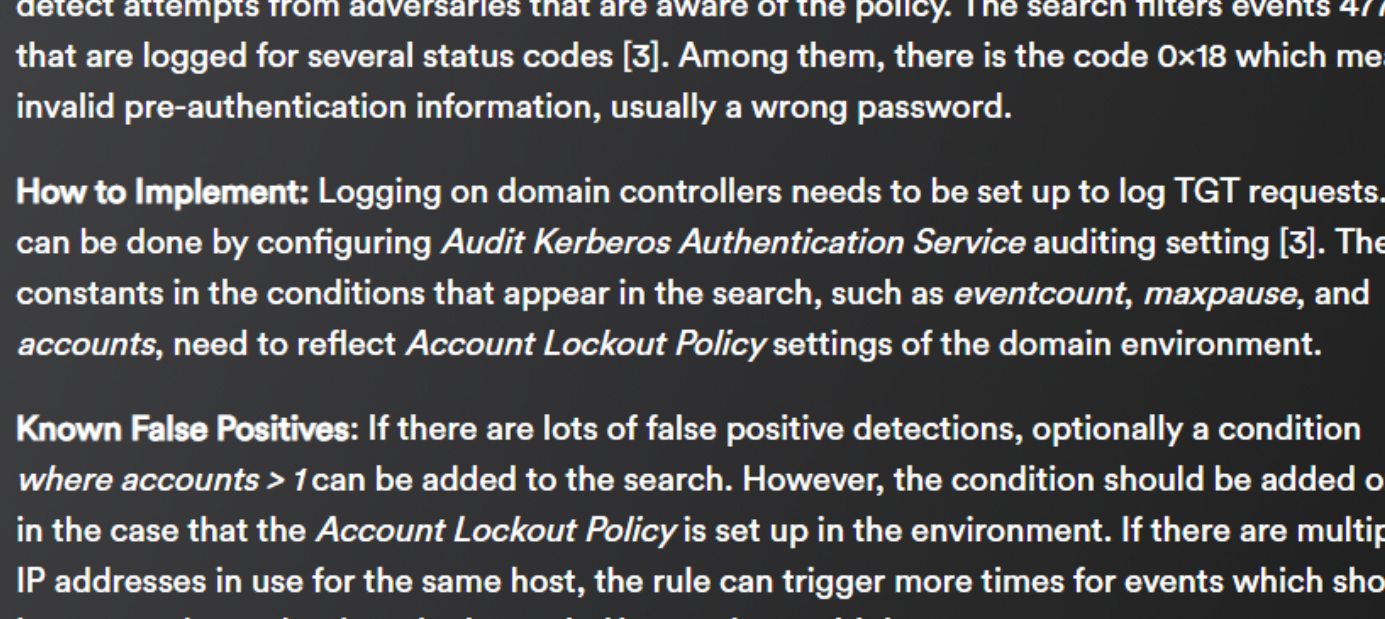
password spraying activity. It searches for attempts where Kerberos authentication was used. The rule can be useful even if the lockout policy is applied in the domain because it can detect attempts from adversaries that are aware of the policy. The search filters events 4771 that are logged for several status codes [3]. Among them, there is the code 0x18 which means invalid pre-authentication information, usually a wrong password.

How to Implement: Logging on domain controllers needs to be set up to log TGT requests. It can be done by configuring *Audit Kerberos Authentication Service* auditing setting [3]. The constants in the conditions that appear in the search, such as *eventcount*, *maxpause*, and *accounts*, need to reflect *Account Lockout Policy* settings of the domain environment.

Known False Positives: If there are lots of false positive detections, optionally a condition *where accounts > 1* can be added to the search. However, the condition should be added only in the case that the *Account Lockout Policy* is set up in the environment. If there are multiple IP addresses in use for the same host, the rule can trigger more times for events which should be grouped together in a single result. Users using multiple accounts on one computer may trigger this rule by accidentally typing the wrong password. This behavior can be limited by setting the search constants precisely for the needs of a particular environment.

- **S01D04 - Excessive failed password attempts from one source (NTLM)**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4771 Status=0x18 | transaction Ip
```



Events   Patterns   Statistics (8)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Source	Target Username	Number of Accounts	Total Attempts
01/21/2019 13:47:36.071633	DC01	WINDOWS10	Win10User	1	10
01/21/2019 13:39:00.324658	DC01	WINDOWS10	Administrator Win10User Win7User	3	31
01/21/2019 13:22:18.616172	DC01	WINDOWS10	Win10User	1	10
01/21/2019 12:56:34.117297	DC01	WINDOWS10	Administrator DefaultAccount Guest Win10User Win7User	8	48

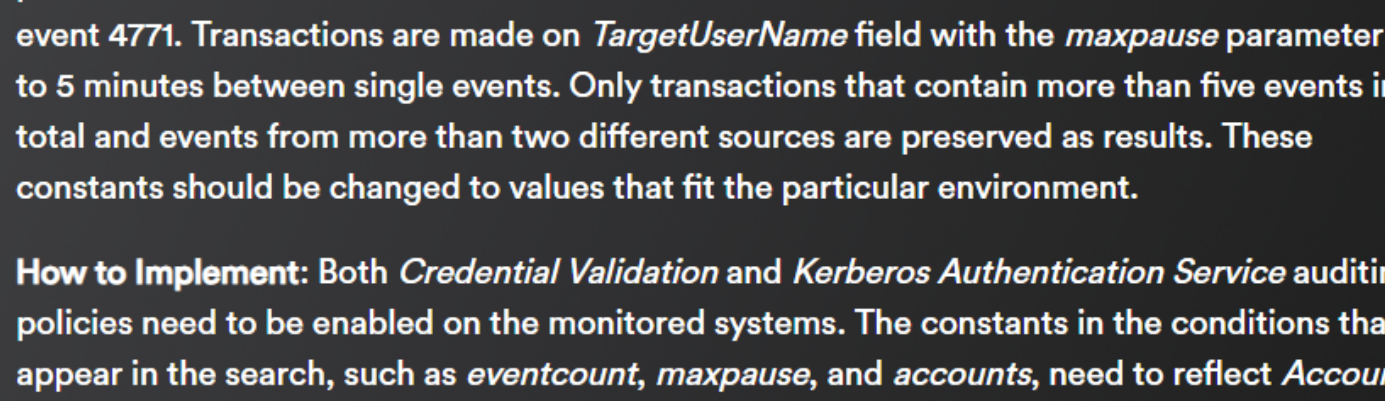
This search detects password brute force attempts coming from one source. Those may be targeting one or multiple accounts, which means this search is also able to identify a password spraying activity. It searches for attempts where NTLM authentication was used. The rule can be useful even if the lockout policy is applied in the domain because it can detect attempts from adversaries that are aware of the policy. The search filters events 4776 that audit NTLM authentication. Status code *0xC000006A* means a logon with misspelled or wrong password [4].

How to Implement: *Credential Validation* auditing policy needs to be enabled on the monitored systems. The constants in the conditions that appear in the search, such as *eventcount*, *maxpause*, and *accounts*, need to reflect *Account Lockout Policy* settings of the domain environment.

Known False Positives: If there are lots of false positive detections, optionally a condition *where accounts > 1* can be added to the search. However, the condition should be added only in the case that the *Account Lockout Policy* is set up in the environment. If there are multiple IP addresses in use for the same host, the rule can trigger more times for events which should be grouped together in a single result. Users using multiple accounts on one computer may trigger this rule by accidentally typing the wrong password. This behavior can be limited by setting the search constants precisely for the needs of a particular environment.

- **S01D05 - Excessive failed password attempts towards one account**

```
index="ad_hunting" source=XmlWinEventLog:Security ((EventCode=4776 Status=0xC000006A) OR (Eve
```



Events   Patterns   Statistics (3)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Target Username	Number of Sources	Source	Total Attempts
02/17/2019 13:08:36.237707	DC01	Administrator	2	192.168.56.106 [illegible]	14
01/21/2019 12:55:27.352164	DC01	Administrator	2	DC01.test.local WINDOWS10	7
01/21/2019 07:35:54.711095	DC01	Win10User	2	DC01.test.local WINDOWS10	6

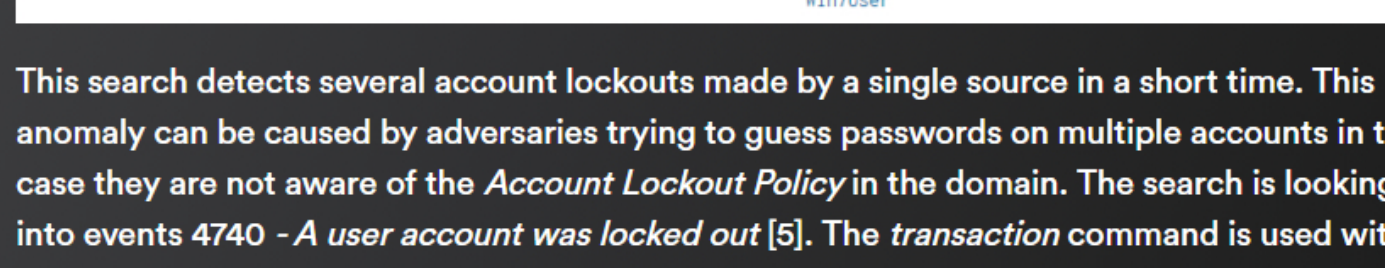
This search detects password brute force attempts towards one target account. Unlike previous searches, this rule is set up to capture trials coming from several sources. Both Kerberos and NTLM authentication events are filtered for status code meaning bad password. That is the status code *0xC000006A* for event 4776 and the status code *0x18* for event 4771. Transactions are made on *TargetUserName* field with the *maxpause* parameter set to 5 minutes between single events. Only transactions that contain more than five events in total and events from more than two different sources are preserved as results. These constants should be changed to values that fit the particular environment.

How to Implement: Both *Credential Validation* and *Kerberos Authentication Service* auditing policies need to be enabled on the monitored systems. The constants in the conditions that appear in the search, such as *eventcount*, *maxpause*, and *accounts*, need to reflect *Account Lockout Policy* settings of the domain environment.

Known False Positives: If some hosts use multiple IP addresses, the number of source hosts may be evaluated wrongly. If the condition for sources is *sources > 1*, the rule can trigger false-positively for the same source host, showing as two events. This happens because the event 4776 logs hostname, while event 4771 logs IP addresses only. It can be fixed by using *lookup*. A single user logging on multiple computers in a short time may trigger this rule by accidentally typing the wrong password. This behavior can be limited by setting the search constants precisely.

- **S01D06 - Multiple locked accounts from one source**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4740 | transaction TargetDomainNa
```



20 Per Page ▾   Format   Preview ▾

Time	Host	Source	Target Username	Number of Accounts
01/21/2019 13:23:47.267625	DC01	WINDOWS10	Administrator Win10User Win7User	3

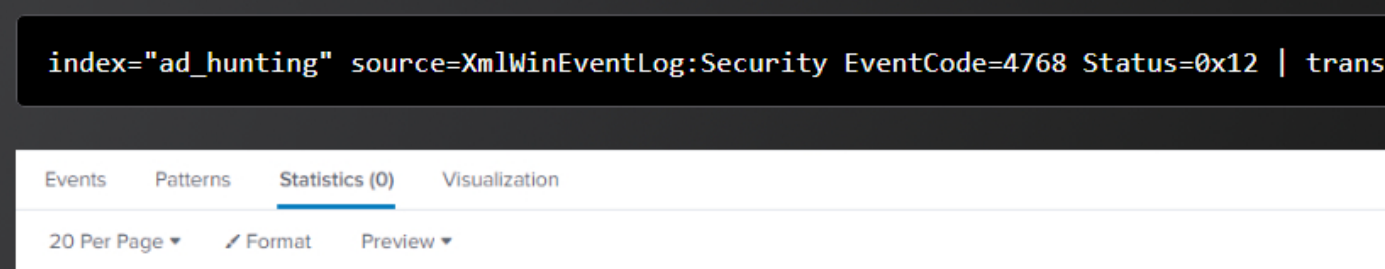
This search detects several account lockouts made by a single source in a short time. This anomaly can be caused by adversaries trying to guess passwords on multiple accounts in the case they are not aware of the *Account Lockout Policy* in the domain. The search is looking into events 4740 - *A user account was locked out* [5]. The *transaction* command is used with the field *TargetDomainName*. This is the field containing the name of computer account from which logon attempt was received. This applies to XML event format; the field is called *Caller Computer Name* in the standard event format. The condition triggers when there is more than one account locked from the same source computer.

How to Implement: *User Account Management* auditing setting enables logging for account lockout events (4740). The constants in the conditions that appear in the search, such as *maxpause*, and *accounts*, need to reflect *Account Lockout Policy* settings of the domain environment. Replacing the condition *accounts > 1* by *eventcount > 1* returns also repetitive lockout attempts for the same account. It can be useful in the case that accounts are being unlocked automatically after some time.

Known False Positives: A user may lock his own multiple accounts by accidentally typing a wrong password. If some computers are shared among several users, these users can lock their accounts in a short time from a single computer.

- **S01D08 - Logon attempts towards disabled accounts (Kerberos)**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4768 Status=0x12 | transaction Ip
```



Events   Patterns   Statistics (0)   Visualization

20 Per Page ▾   Format   Preview ▾

No results found.

This search identifies repetitive logon attempts with the use of disabled accounts. This rule detects attempts where Kerberos authentication was used. An attacker may want to exploit forgotten accounts that are no longer used in the environment. Or eventually, also default Windows built-in accounts in the case they are disabled. The search is focusing on events 4768 with the status code *0x12*, which means that the account is disabled [3]. Transactions are made on the *IpAddress* field, and only those containing more than five matches are kept in the results. This condition detects signs of a brute force activity. The number of target accounts is evaluated by using the *mvcount* function on the field *TargetUserName*. Only transactions with more than two accounts are displayed.

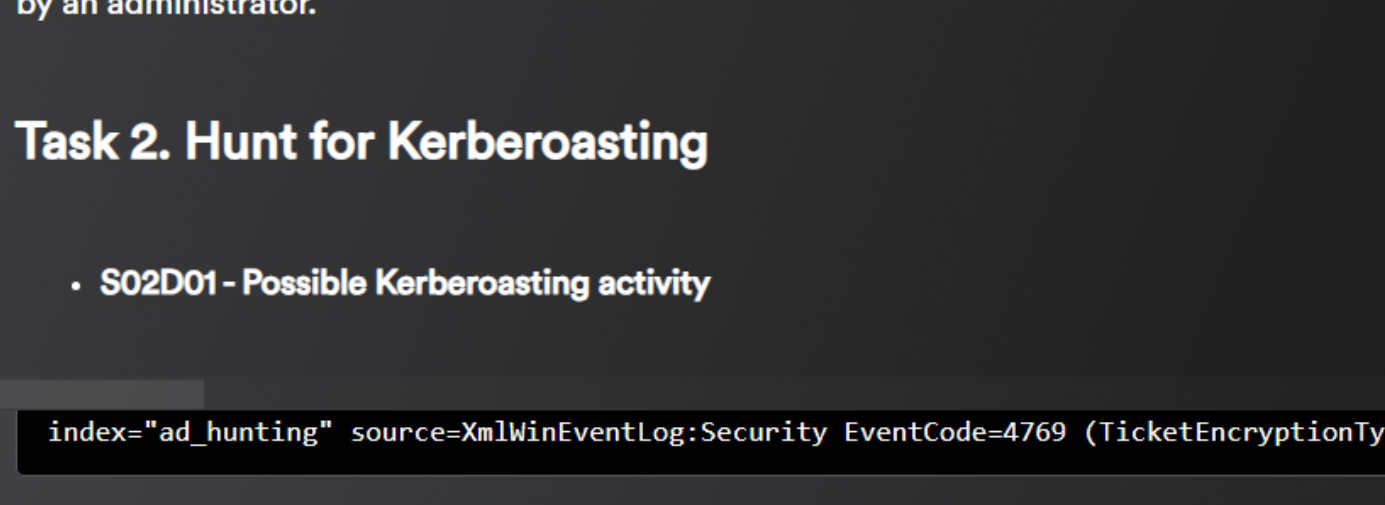
How to Implement: Logging on domain controllers needs to be configured to audit *Kerberos Authentication Service*. Note that event 4768 with status code *0x12* means a disabled account, whereas the event 4771 with status code *0x12* means that the account is locked.

Known False Positives: Some logon attempts can occur shortly after the account is disabled by an administrator.

Task 2. Hunt for Kerberoasting

- **S02D01 - Possible Kerberoasting activity**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4769 (TicketEncryptionType=0x1 OR
```



Events   Patterns   Statistics (27)   Visualization

20 Per Page ▾   Format   Preview ▾   ‹ Prev 1 2 Next ›

Time	Host	Source	Target Username	Service Name	Ticket Encryption
04/10/2019 09:47:51.1597332	DC01	192.168.56.104	Win7User@TEST.LOCAL	krbtgt	0x17
04/10/2019 09:37:14.0809748	DC01	192.168.56.105	Win7User@TEST.LOCAL	krbtgt	0x17
04/10/2019 09:35:39.8343732	DC01	192.168.56.105	Win7User@TEST.LOCAL	krbtgt	0x17
03/31/2019 11:19:13.0060172	DC01	DC01.test.local	Administrator@TEST.LOCAL	Honeypot01	0x17
03/31/2019 11:15:31.7738503	DC01	192.168.56.104	Win7User@TEST.LOCAL	Honeypot01	0x17
03/31/2019 11:03:15.1105492	DC01	192.168.56.104	Win7User@TEST.LOCAL	Honeypot01	0x17
03/31/2019 11:03:15.0725865	DC01	192.168.56.104	Win7User@TEST.LOCAL	Database01	0x17

This search finds sources that requested service tickets with weak cipher suites. These encryption types should be no longer used by modern operating systems in the domain. Therefore, they are likely signs of possible Kerberoasting activity. The search looks at events 4769 auditing service ticket requests. It filters for any ticket requests with encryption type constants equal to the values of vulnerable cipher suites. List of all encryption types can be found at [8]. All requests for tickets with these encryption types are displayed.

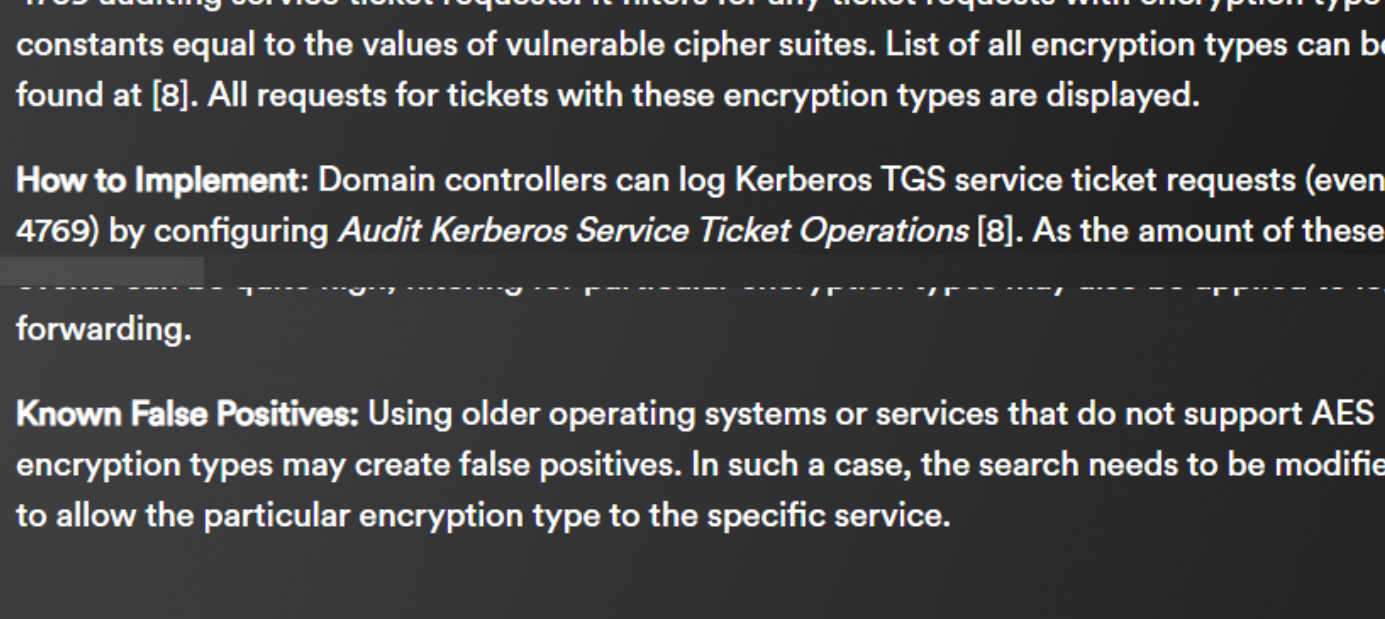
How to Implement: Domain controllers can log Kerberos TGS service ticket requests (event 4769) by configuring *Audit Kerberos Service Ticket Operations* [8]. As the amount of these

forwarding.

Known False Positives: Using older operating systems or services that do not support AES encryption types may create false positives. In such a case, the search needs to be modified to allow the particular encryption type to the specific service.

- **S02D02 - Excessive service ticket requests from one source**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4769 ServiceName != krbtgt | rege
```



Events   Patterns   Statistics (5)   Visualization

20 Per Page ▾   Format   Preview ▾

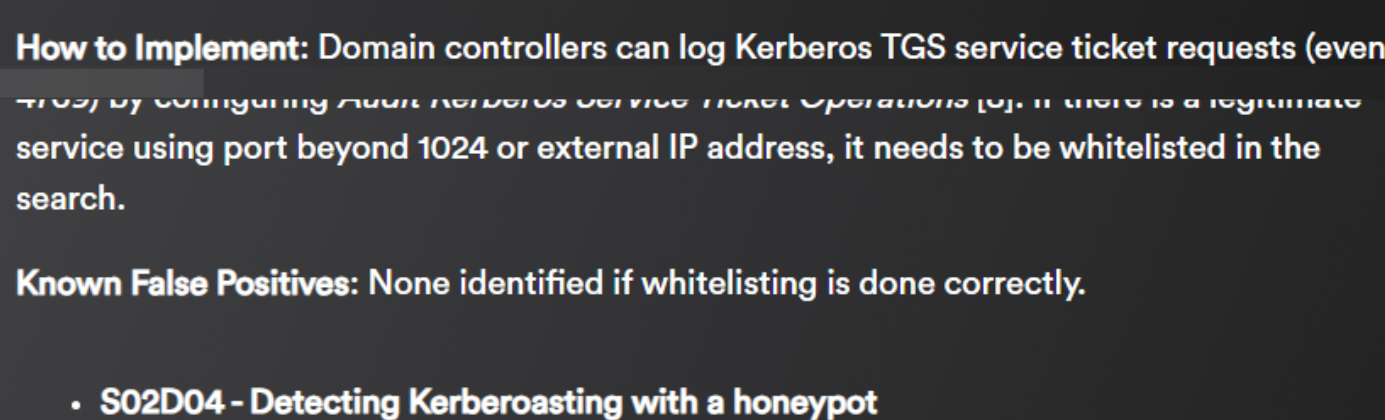
Time	Host	Source	Target Username	Number of Services	Service Name	Ticket Encryption
03/31/2019 11:03:15.072586	DC01	192.168.56.104	Win7User@TEST.LOCAL	2	Database01 Honeypot01	0x17
03/31/2019 10:58:51.260334	DC01	192.168.56.105	Win7User@TEST.LOCAL	2	Database01 Honeypot01	0x17
03/31/2019 10:42:20.003056	DC01	192.168.56.105	Administrator@TEST.LOCAL	2	Database01 Honeypot01	0x17
02/02/2019 03:16:51.240982	DC01	DC01.test.local	Administrator@TEST.LOCAL	2	Database01 Honeypot01	0x17
08:12:40.045924					Honeypot01	

Requests for several different service names (not related to each other) within a short time period from a single account are suspicious. Even more so if weak encryption was used in the service tickets. This search may help to reveal such activities. Service ticket requests for *krbtgt* service and computer account service names (those ending with $) are filtered out from the results. The search focuses on service accounts that were created for specific services. Subsequent events are grouped on the *IpAddress* field by the transaction command. Number of services in each transaction is calculated to display only results where the number is higher than the one specified in the condition.

How to Implement: Domain controllers can log Kerberos TGS service ticket requests (event 4769) by configuring *Audit Kerberos Service Ticket Operations* [8]. The search constant indicating the number of services needs to be tuned to the needs of a particular domain environment.

Known False Positives: The assessment of whether services are related or not needs to be added to the search if possible. Otherwise it needs to be done manually by a security analyst. Narrowing the search for particular ticket encryption types may prevent false positives. This search may also be combined with detection search S02D01 which could help to prevent false positive detections.

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4769 IpPort > 0 (IpPort < 1024 OR
```



20 Per Page ▾   Format   Preview ▾   ‹ Prev 1 2 Next ›

Time	Host	Source	Source Port	Target Username	Service Name	Ticket Encryption
12/18/2018 04:03:45.0819352	DC01	::ffff:192.168.56.103	50154	Win10User@TEST.LOCAL	DC01$	0x12
12/18/2018 02:47:19.0378882	DC01	::ffff:192.168.56.103	49985	Win10User@TEST.LOCAL	DC01$	0x12
12/18/2018 02:47:18.9071509	DC01	::ffff:192.168.56.103	49983	Win10User@TEST.LOCAL	krbtgt	0x12

The above is due to the Source being logged improperly. There is no such activity in this lab's dataset.

This search tracks service requests by examining the IP address and port number. Unusual values indicate the use of outbound connection for the service request, which is suspicious. The search examines the *IpPort* and *IpAddress* fields in events 4769. Port values under 1024 and any non-private IP addresses are those of interest. The search displays results whenever such values appear in the request, together with details about the requestor.

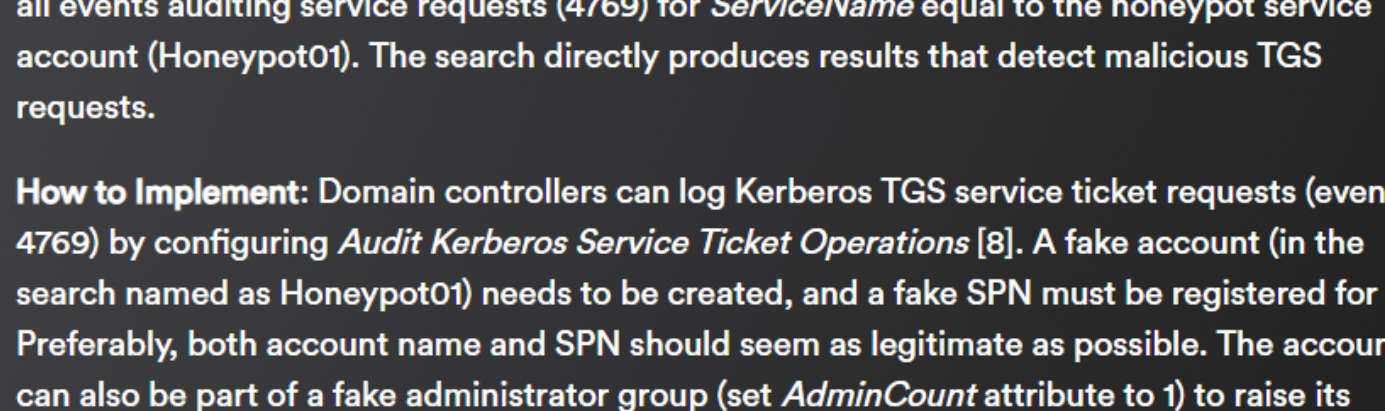
How to Implement: Domain controllers can log Kerberos TGS service ticket requests (event

service using port beyond 1024 or external IP address, it needs to be whitelisted in the search.

Known False Positives: None identified if whitelisting is done correctly.

- **S02D04 - Detecting Kerberoasting with a honeypot**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4769 ServiceName=Honeypot01 | eva
```



Events   Patterns   Statistics (9)   Visualization

20 Per Page ▾   Format   Preview ▾

Time	Host	Source	Target Username	Service Name	Ticket Encryption
03/31/2019 11:19:13.0060172	DC01	DC01.test.local	Administrator@TEST.LOCAL	Honeypot01	0x17
03/31/2019 11:15:31.7738503	DC01	192.168.56.104	Win7User@TEST.LOCAL	Honeypot01	0x17
03/31/2019 11:03:15.1105492	DC01	192.168.56.104	Win7User@TEST.LOCAL	Honeypot01	0x17
03/31/2019 10:58:51.2603345	DC01	192.168.56.105	Win7User@TEST.LOCAL	Honeypot01	0x17

This search uses a detection method for Kerberoasting based on a honeypot. Honeypot is a fake service account that is never really used in the environment, but it is set up to look like a legitimate service account with high privileges assigned. A service ticket requests for this

all events auditing service requests (4769) for *ServiceName* equal to the honeypot service account (Honeypot01). The search directly produces results that detect malicious TGS requests.

How to Implement: Domain controllers can log Kerberos TGS service ticket requests (event 4769) by configuring *Audit Kerberos Service Ticket Operations* [8]. A fake account (in the search named as Honeypot01) needs to be created, and a fake SPN must be registered for it. Preferably, both account name and SPN should seem as legitimate as possible. The account can also be part of a fake administrator group (set *AdminCount* attribute to 1) to raise its attractivity for an attacker. More details about the implementation can be found at [9].

Known False Positives: There should not be any false positives. There is no reason to request a service ticket for the honeypot service by a legitimate user.

- **S02D05 - Detecting Kerberoasting via PowerShell**

```
index="ad_hunting" source="WinEventLog:Microsoft-Windows-PowerShell/Operational" (EventCode=4
```

This search is provided for completeness' sake. It won't produce any results.

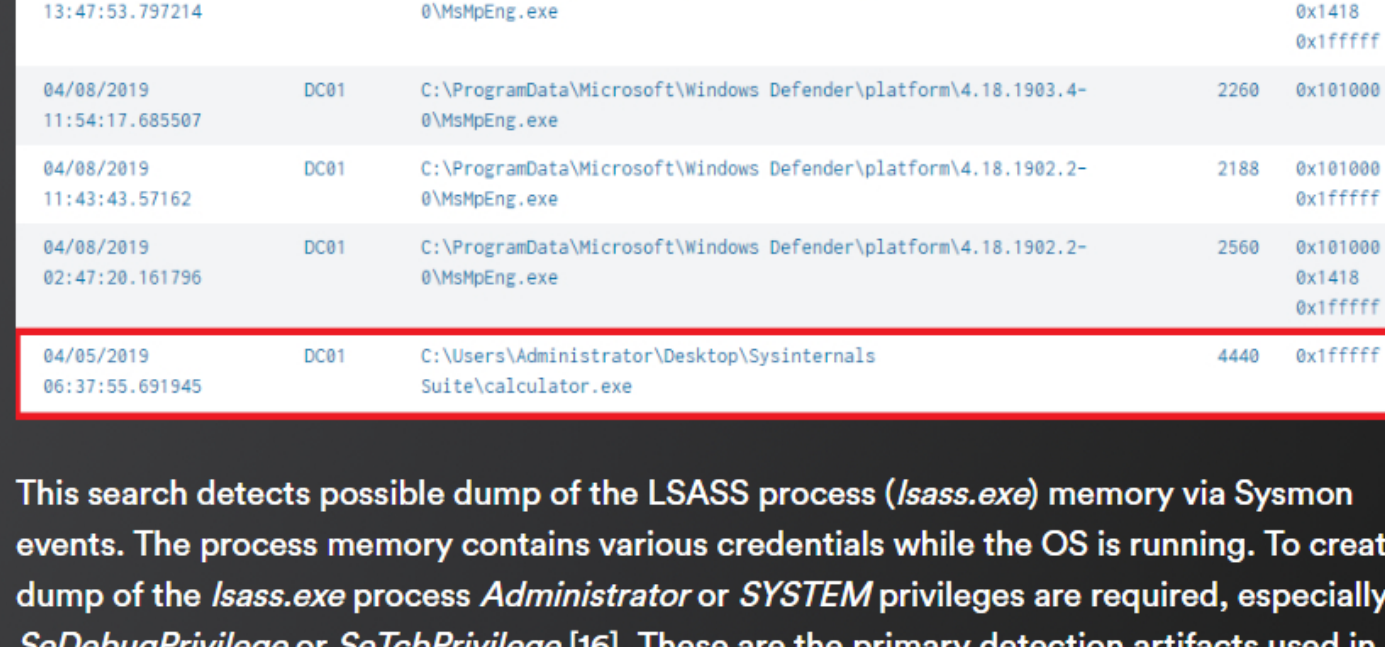
This search detects attempts to manipulate with service accounts via PowerShell. PowerShell

successful acquisition of the service ticket hash. Computers that appear in the results of this search with an extensive amount of events are worth to investigate. The search is built on events from *PowerShell Operational* log. A transaction is created for all subsequent PowerShell events coming from a single workstation. A new field named *raw* is created and assigned the entire raw event. This is a preparation for the full-text search used in the next step. The search looks for the occurrence of any service account in the raw data of the PowerShell events. The list of service accounts is provided by a lookup file *service_accounts.csv*. Only the transactions containing more suspicious events than the specified threshold are displayed in the results.

Task 3. Hunt for Credential Dumping

- **S03D01 - Possible dump of lsass.exe (Sysmon events)**

```
index="ad_hunting" source="xmlwineventlog:microsoft-windows-sysmon/operational" EventCode=8 (
```



20 Per Page ▾   Format   Preview ▾

Time	Host	Process	Process ID	Access Mask
				0x1418 0x1fffff
04/09/2019 13:47:53.797214	DC01	C:\ProgramData\Microsoft\Windows Defender\platform\4.18.1903.4-0\MsMpEng.exe	2168	0x101000 0x1418 0x1fffff
04/08/2019 11:54:17.685507	DC01	C:\ProgramData\Microsoft\Windows Defender\platform\4.18.1903.4-0\MsMpEng.exe	2260	0x101000
04/08/2019 11:43:43.57162	DC01	C:\ProgramData\Microsoft\Windows Defender\platform\4.18.1902.2-0\MsMpEng.exe	2188	0x101000 0x1fffff
04/08/2019 02:47:20.161796	DC01	C:\ProgramData\Microsoft\Windows Defender\platform\4.18.1902.2-0\MsMpEng.exe	2560	0x101000 0x1418 0x1fffff
04/05/2019 06:37:55.691945	DC01	C:\Users\Administrator\Desktop\Sysinternals Suite\calculator.exe	4440	0x1fffff

This search detects possible dump of the LSASS process (*lsass.exe*) memory via Sysmon events. The process memory contains various credentials while the OS is running. To create a dump of the *lsass.exe* process *Administrator* or *SYSTEM* privileges are required, especially *SeDebugPrivilege* or *SeTcbPrivilege* [16]. These are the primary detection artifacts used in this search. It is essential to focus on processes that accessed *lsass.exe* with these privileges. The search is focusing on Sysmon events with event codes 10 (*ProcessAccess*) and 8 (*CreateRemoteThread*). These events are logged when a process creates another process or thread. The search focuses on processes interacting with lsass.exe with access mask specifying higher privileges. This is achieved by whitelisting the low-privileged access masks. List of access masks can be found at [17]. It is possible to whitelist some processes that

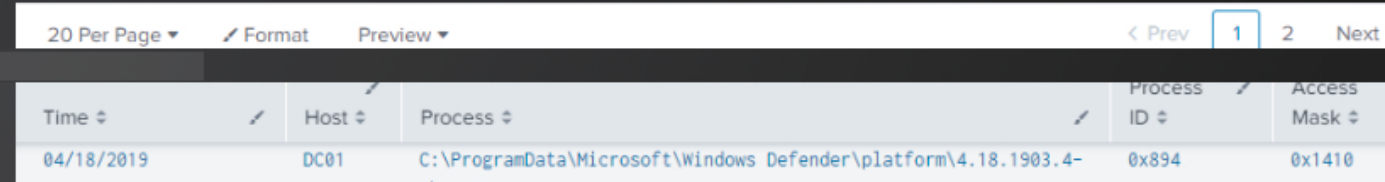
specify the full path to the process, as the name and the location of the executable can be easily changed to look like a legitimate process. The transaction command is used to group accesses of the same process in a short period. Process name and ID are displayed for further investigation.

How to Implement: Sysmon must be deployed and configured to log process accesses(event10), and optionally creation of remote threads (event 8). The logs must be ingested and parsed by using TA for Microsoft Sysmon [18]. Whitelisting of processes needs to be done carefully. Only full process paths should be whitelisted. Malicious processes may have their name spoofed to look like a legitimate process.

Known False Positives: Some processes may need to access lsass.exe with higher privileges. Depending on the services used in the environment, these processes can be whitelisted to prevent false positives. Examples are common Windows processes or AV solution processes (e.g., Windows Defender).

- **S03D02 - Possible dump of lsass.exe (Windows events)**

```
index="ad_hunting" source=XmlWinEventLog:Security EventCode=4656 NOT AccessMask=0x1400 NOT Ac
```



20 Per Page ▾   Format   Preview ▾   ‹ Prev 1 2 Next ›

Time	Host	Process	Process ID	Access Mask
04/18/2019	DC01	C:\ProgramData\Microsoft\Windows Defender\platform\4.18.1903.4-	0x894	0x1410